

PHOENIX – Security Validation Checklist

Prepared by:	Vipul
Role:	Cybersecurity Team Member
Project:	PHOENIX
Deliverable:	Threat Analysis Integration - Security Validation Checklist

1. Purpose & Overview

The purpose of this Security Validation Checklist is to establish a rigorous, standardized verification framework for the PHOENIX Threat Analysis Integration. It audits and validates that every security control defined during Sprint 1 architecture and design is properly implemented, enforced, and verified across all integration layers.

This checklist ensures that external interfaces, internal processing pipelines, and output channels remain resilient against tampering, unauthorized access, injection attacks, and data leakage.

2. Traceability & Scope Alignment

This checklist translates the architectural security commitments into actionable verification criteria across our project artifacts:

[Source Alignment: Mannat & Dilano – Design Document Sec. 8 & Testing Plan Sec. 7 (Security Test Cases SIT-01..09)]

- **Security Controls Baseline:** Verifies all 8 foundational security controls documented in Mannat's Threat Analysis Integration Design Document (Section 8).
- **API Specification Compliance:** Validates endpoint security requirements, JWT headers, and status codes specified in Vipul's API Data Exchange Specification.
- **Security Test Plan Mapping:** Correlates directly to the Security Integration Test scenarios (SIT-01 through SIT-09) defined in Dilano's Integration Testing Plan.

3. Comprehensive Security Validation Checklist

[Source Alignment: Mannat & Dilano – Design Doc Sec. 8 & Testing Plan Sec. 7]

The matrix below details each security control ID, verification area, validation criteria, target component, related testing plan ID, and current Sprint 1 design verification status:

Checklist ID	Security Area	Validation Requirement & Criteria	Target Layer	Test Case Ref	Design Status
SVC-01	Transport Security	Enforce TLS 1.3/HTTPS on all endpoints; reject unencrypted HTTP traffic.	API Gateway / Endpoints	SIT-01	Verified / Designed

SVC-02	Authentication	Validate JWT Bearer token on every protected request; reject missing/expired tokens with HTTP 401.	Auth Layer / Ingestion	SIT-02	Verified / Designed
SVC-03	Access Control (RBAC)	Enforce least-privilege role permissions (EventProducer, ThreatAnalyst, Admin); return HTTP 403 on unauthorized actions.	All Services & Endpoints	SIT-03	Verified / Designed
SVC-04	Input Validation	Strictly validate JSON schema, field types, and sanitize inputs to block injection and malformed payloads (HTTP 400).	Collection & Ingestion	SIT-04	Verified / Designed
SVC-05	Rate Limiting & Anti-DDoS	Enforce threshold of 100 requests/minute per client IP/token; return HTTP 429 when threshold exceeded.	API Gateway / Ingestion	SIT-05	Verified / Designed
SVC-06	Secure Error Handling	Sanitize all error responses to prevent system stack traces, database schemas, or server details from leaking (HTTP 500/400).	All Microservices	SIT-06	Verified / Designed
SVC-07	Data Integrity & Hashing	Verify cryptographic checksums/hashe s for high-severity threat payloads to prevent payload tampering in	Internal Bus & Storage	SIT-07	Verified / Designed

		transit.			
SVC-08	Audit Logging & Traceability	Log all security events, analysis results, and decision triggers with immutable timestamps and correlation tracking IDs.	Output Layer / Audit DB	SIT-08	Verified / Designed
SVC-09	Service Isolation & Resilience	Ensure service fallback and graceful degradation when ADCRS or secondary engines experience timeout or disconnect.	Threat Analysis Engine	SIT-09	Verified / Designed

4. Security Verification Methodology

To ensure comprehensive validation across development and deployment phases, security controls will be evaluated using three complementary testing methods:

- **1. Static Design & Schema Review:** Verifying that OpenAPI schemas, data models, and access control policies adhere to zero-trust principles before code implementation.
- **2. Automated Integration & Vulnerability Testing:** Executing automated test suites (covering SIT-01 through SIT-09) with positive, negative, boundary, and fuzzing payloads during build cycles.
- **3. Penetration & Fault Injection Testing:** Simulating token tampering, brute force replay attacks, malformed JSON inputs, and upstream service failures to confirm graceful and secure system degradation.

5. Summary

The Security Validation Checklist provides a clear roadmap for securing the PHOENIX Threat Analysis Integration. By aligning design principles from Mannat, workflow and testing requirements from Dilano, and technical API contracts from Vipul, this checklist guarantees that security is built directly into the architecture rather than treated as an afterthought.